Analysis of Health Information Privacy Reform Act

Aesha Shah

Abstract— **S.3097, The Health Information Privacy Reform Act (HIPRA) seeks to expand federal health data privacy protections beyond traditional HIPAA covered entities. In this paper, I evaluate the Act's ethical, legal, and technical implications. The first section argues in favor of the bill, while the second section opposes, and the third section provides a recommendation.**

Index Terms*— *health data privacy, Health Insurance Portability and Accountability Act (HIPAA), Health Information Privacy Reform Act (HIPRA), minimum necessary data, digital health

I. Supporting HIPRA

Senator Moderate, it is tempting to read S.3097, the Health Information Privacy Reform Act [1], and think we're simply updating HIPAA for the 21st century, but that understates the problem. This bill confronts a hard truth: health privacy law from 1996 that no longer matches how health information is created, sold, and used today [2]. The text of HIPRA makes this explicit: it defines "applicable health information" as information that identifies individuals and relates to their physical or mental condition or health care even if the information was not created or received by a provider, health plan, or health care clearinghouse [3]. In other words, this bill covers data no one ever anticipated in 1996, and I encourage you to vote in favor of it.

Location patterns, search histories, and mobile sensor data can signal pregnancy, heart conditions, or chronic disease risks without a single doctor visit [4]. Companies like data brokers and app developers operate outside HIPAA's "covered entity" regime and build business models around these inferences. The Federal Trade Commission (FTC) and privacy regulators have repeatedly highlighted this health privacy crisis, warning that personal health information is being "harvested, sold, and used beyond our control" [5]. Part of the reason this happens is that under current law, a fitness tracker or symptom-checker app can generate and trade information that exposes health status, yet face no federal regime comparable to HIPAA.

S.3097 directs the United States Department of Health and Human Services (HHS), with FTC input, to set privacy, security, and breach rules for all regulated entities handling health-related data. Another piece worth underlining (because it is easy to overlook but essential) is the bill's focus on minimum necessary (requesting personal health information limited to the specific purpose).

S.3097 explicitly extends this standard to health data in modern computing systems. In systems designed to aggregate and reuse data at scale, requiring transparency and consent for secondary uses (such as repurposing location data for profiling) cuts off hidden data pipelines and forces accountability.

When people understand that their reproductive health data, mental health signals, or genetic risk scores are governed by meaningful safeguards (not just user agreements), they are more likely to use these tools and share data in ways that benefit individuals and public health. S.3097 recognizes the realities of data markets, sets a path for explicit privacy protections, and puts regulated entities on notice that health-related data does not exist in a legal vacuum.

II. Opposing HIPRA

Senator Moderate, the intent of S.3097 is clear, but the implementation risks collide with reality; for this reason I encourage you to vote against it.

Definitions matter more than they seem here. S.3097's definition of "applicable health information" is broad by design, but its breadth is also its primary risk. It would include any data that could reasonably be used to identify an individual and relate to health (specifically created by a non-traditional health entity): step counts, sleep patterns, behavioral analytics, and more [6].

The bill places minimum necessary obligations on regulated entities without clear statutory guidance on how to apply them in practice, especially for technologies like artificial intelligence (AI). AI systems learn by identifying patterns across many examples. Training on large and diverse datasets is necessary to improve accuracy, reduce bias, and avoid fragile or unsafe results, extending beyond narrowly defined health information [7]. When you tell a new company that every bit of that training data must be justified *ex ante* under a minimum necessary standard, you are telling them to choose between compliance risk and innovation risk. This requirement creates uncertainty, not accountability.

Many small businesses already struggle to allocate resources for privacy and security compliance and must navigate a fragmented U.S. privacy landscape with overlapping state and federal requirements [8]. Layering HIPRA's broad scope on top of these existing obligations increases the likelihood of severe financial penalties rather than improved privacy outcomes [9]. For example, a small fitness app startup could face six-figure penalties if HIPRA classifies aggregated step counts or sleep patterns as protected health information, a burden that could threaten the company's viability even without providing any clinical services.

And last, this bill does very little to harmonize with state standards. In states like New York, broader definitions of "medical information" are starting to shape non-HIPAA breach notification law for non-HIPAA entities [10]. If we push a broad federal law without reconciling those state efforts, the result would be a host of confusion.

In its current form, S.3097 is burdened with uncertainties, enforcement gaps, and overly broad definitions that would do more harm than good.

III. Author's Recommendation

Senator Moderate, after considering sides, I recommend that you not support S.3097 in its current form. The bill addresses a real problem: the loss of meaningful privacy protections for health-related data outside HIPAA's traditional scope. But it does so in a way that is too broad and hinders critical technical innovation.

A more sustainable path would be to insist on targeted amendments before advancing the bill. These could include:

- a narrower definition of applicable health information that focuses on data used to generate medical inferences, not every health-adjacent telemetry stream
- statutory language clarifying how minimum necessary applies to iterative and AI-driven development
- enforceability metrics and funding pathways for HHS and FTC enforcement capacity
- transitional compliance periods for small and mid-sized developers
    - for example, under 45 CFR §164.534, "small health plans" are allotted an additional year [11].

Such revisions would make the law more workable without abandoning the principle that health data deserves protection wherever it is generated and used. Passing legislation that is too broad could do more damage than passing none at all.

References

[1] U.S. Senate. 119th Congress, 1st Session, (2025, Nov. 4). S.3097 - Health Information Privacy Reform Act. [Online]. Available: https://www.congress.gov/bill/119th-congress/senate-bill/3097/text

[2] M. Goldman, "HHS enforcement of health data privacy is lacking: report," Axios, Nov. 26, 2024. [Online]. Available: https://www.axios.com/2024/11/26/hhs-enforcement-health-data-privacy-hipaa-report

[3] "Health Information Privacy Reform Act Introduced in Senate," LUGPA, 2025. [Online]. Available: https://www.lugpa.org/health-information-privacy-reform-act-introduced-in-senate

[4] J. L. Kilgallon, I. A. Tewarie, M. L. D. Broekman, A. Rana, and T. R. Smith, "Passive Data Use for Ethical Digital Public Health Surveillance in a Postpandemic World," in *Journal of Medical Internet Research*, Feb. 2022. [Online]. Available: https://www.jmir.org/2022/2/e30524

[5] S. Geoghegan, S. Bernstein, A. Butler, T. McBrien, and M. Tobin-Miyaji, "Beyond HIPAA: Reimagining How Privacy Laws Apply to Health Data to Maximize Equity in the Digital Age," Electronic Privacy Information Center (EPIC), Washington, DC, Jan. 21 2026. Accessed: Feb 1 2026. [Online]. Available: https://epic.org/wp-content/uploads/2026/01/EPIC-Beyond-HIPAA-Jan2026.pdf

[6] K. Peremore, "New bill targets wearables as Congress moves to close health privacy gap," HIPAA Times, Nov. 11, 2025. [Online]. Available: https://hipaatimes.com/new-bill-targets-wearables-as-congress-moves-to-close-health-privacy-gap

[7] K. Thomas, Sudeep Edpuganti, D. Puthooran, A. Thomas, A. Joy, and Shifna Latheef, "Artificial intelligence in modern clinical practice (Review)," in *Medicine International*, Dec. 2025. [Online]. Available: https://www.spandidos-publications.com/10.3892/mi.2025.289

[8] Avatier, "HIPAA Violations: Small Business vs Enterprise Trends - Avatier," Avatier, 2025. [Online]. Available: https://www.avatier.com/blog/hipaa-businesses-vs-enterprises/

[9] I. James, "Why Small Businesses in the US Struggle with Privacy Compliance," Privacy Needle, Oct. 18, 2025. [Online] Available: https://privacyneedle.com/compliance/legislation/why-small-businesses-in-the-us-struggle-with-privacy-compliance/

[10] "New York Health Data Requirements Potentially Ahead: Understanding the Newly Passed Health Information Privacy Act," Ogletree, Mar. 11, 2025. [Online]. Available: https://ogletree.com/insights-resources/blog-posts/new-york-health-data-requirements-potentially-ahead-understanding-the-newly-passed-health-information-privacy-act/

[11] "45 CFR 164.534 -- Compliance dates for initial implementation of the privacy standards.," ECFR, 2026. [Online]. Available: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-E/section-164.534